Mindsmiths	Application and Interface Security Policy			
	ID	AIS	**Author**	Tin Ceraj
	Version	1.0	**Date**	29.04.2020.

Content

History of Changes in documented informations 1

API standards 2

Data validation 3

Data access 4

API interoperability 4

History of Changes in documented informations

Date	Created by	ID	Version	Change

API standards

1. All APIs that will be used within the platform should be protected with IP address whitelisting and authentication. The ones that will be used as endpoints for any purpose outside the platform, should have at least basic authentication and adequate protection depending on the data sensitivity and potential requirements made by the client.
2. When creating or editing an existing API, any changes made are reviewed by a person with OWASP standards knowledge, usually that being a tech lead on the project. The API should then be tested with unit tests and in a sandbox environment.
3. For more sensitive information, additional steps are required, depending on the level of information sensitivity.

Data validation

1. Data validation code is required to validate all data created outside the platform before it can enter the platform.
2. Data validation code should be reviewed by a person with OWASP standards knowledge, usually that being a tech lead on the project, and tested with unit tests and in a sandbox environment. Additionally, the code should be subjected to periodical testing in order to detect any bugs or errors which might have emerged as a result of changes made outside the platform between the tests.
3. Same goes for the output data, the entire code which communicates with anything outside the platform should also be reviewed by a person with OWASP standards knowledge, usually that being a tech lead on the project, and tested with unit tests and in a sandbox environment.
4. If the error is detected in the data validation process, a list of steps should be taken in order to fix it. First, we should verify that all the existing data in the platform is unaffected. If it is affected, we need to make sure all decisions we make are aware of that. If we detect that the problem originated from our client's data, our tech lead on the project should communicate it with the client's contact in charge.

Data access

1. Access to data stored on a project should be regulated based on data sensitivity and whether the data is required for working on the project. When any data is extracted from the platform for any kind of evaluation, any parts that can be used for malicious purposes should be anonymized using irreversible hash functions.
2. Each project should go through periodic data sensitivity evaluations which might further increase measures taken to ensure data security.

API interoperability

1. All open APIs should not be changed under normal circumstances. Changing any open API is considered a breaking change in which case the client using the API must be notified and should confirm that they are ready for the change.